

Information Security Policy

Northwind Systems GmbH

Document ID: SEC-POL-001

Version: 7.2

Effective date: 1 February 2026

Owner: Information Security

Classification: Internal

Review cycle: Semi-annual

Approved by: Executive Board, 21 January 2026

1. Purpose and Applicability

This policy sets the mandatory security obligations of everyone who works for or on behalf of Northwind Systems: employees, contractors, interns and third parties with access to company systems or premises.

Compliance is a condition of continued access. Where an obligation cannot be met for a legitimate operational reason, an exception must be granted in writing by Information Security before the obligation is departed from; it is never acceptable to work around a control silently.

Suspected or actual breaches of this policy are reported under the incident response plan.

2. Information Classification

Every piece of company information carries one of four classifications. Where no classification is marked, treat the information as Internal.

- **Public** -- Approved for release outside the company. Marketing material, published documentation, press statements.
- **Internal** -- The default. Ordinary business information whose disclosure would be unwelcome but not damaging. Most policies, process documents and internal communication.
- **Confidential** -- Disclosure would cause material harm. Customer data, contracts, financial results before publication, personnel records, source code.
- **Restricted** -- Disclosure would cause severe harm. Authentication secrets, cryptographic keys, security assessment findings, merger and acquisition material.

The classification travels with the information. Extracting Confidential data into a spreadsheet, a chat message or a presentation does not make it Internal.

3. Authentication and Credentials

3.1 Passphrase standard

Every account used for company purposes must meet the following:

- A minimum length of fourteen characters. Length is the dominant factor in resistance to offline attack; a long, memorable phrase is stronger than a short string with substitutions.
- No reuse of any of the account's previous five secrets. The identity platform enforces this at the point of change.
- No reuse of a secret that is used on any account outside the company, whatever its length.
- Immediate replacement where the secret is known or suspected to have been exposed, without waiting to be prompted.

There is no mandatory rotation interval. Scheduled expiry is deliberately not enforced, because it drives predictable, incremental variations that weaken rather than strengthen the credential. Replacement on suspicion of exposure is required instead.

3.2 Multi-factor authentication

Multi-factor authentication is mandatory on every account that supports it, without exception and regardless of the sensitivity of the account.

The approved second factors are the company authenticator application and hardware security keys. Delivery of one-time codes over SMS or voice call is not approved and is disabled at the identity platform, because both are defeated by number porting.

An authentication prompt that the employee did not initiate is a reportable security event, not an inconvenience to be dismissed. Report it under the incident response plan.

3.3 Credential storage

Use of the company-provided credential vault is mandatory for every work-related secret. Employees are not expected to memorise their credentials, and the vault is the only approved place to hold them.

Secrets must never be held in a browser's built-in store, in a note-taking application, in a spreadsheet, in a chat message, in a ticket, or on paper.

Credentials are personal and are never shared, including with a line manager, including with the IT service desk, and including temporarily. Where two people genuinely need access to the same system, two accounts are provisioned. Where a shared service account is unavoidable, it is held in the vault with access granted per person and audited quarterly.

3.4 Application secrets

API keys, tokens, certificates and connection strings are Restricted. They are held in the secrets manager and injected at runtime. They must never be committed to source control, including to a private repository and including in a commit that is later reverted -- history is not a delete.

Automated secret scanning runs on every push. A detected secret is treated as exposed and must be revoked and reissued, not merely removed from the code.

4. Handling and Storage of Company Data

4.1 Approved locations

Company information may be held only in the corporate storage services designated by IT Operations: the corporate document platform, the managed file shares, the approved source control platform, and the sanctioned line-of-business systems.

These services are the only locations that are backed up, retained according to the data retention schedule, covered by the company's data processing agreements, and recoverable when an employee's device fails or they leave.

4.2 Prohibited locations

Company information must not be placed in any of the following:

- Consumer cloud storage or file synchronisation accounts registered to the individual rather than to the company. This prohibition covers personal accounts on any consumer file storage or document service, whatever the provider, and applies even where the account belongs to an employee and the folder is not shared with anyone.
- Personal e-mail accounts, including sending a document to a private address in order to work on it at home.
- Personal messaging applications.
- Unmanaged personal devices, including personal computers, tablets and telephones.
- Removable media that is not company-issued and encrypted.
- Third-party online services that have not been assessed, including document converters, transcription services, translation services and generative artificial intelligence tools not on the approved list.

There is no permitted exception for convenience, for a deadline, or for information the employee judges to be harmless. The classification of the data does not create an exception either: Internal data in a personal account is still a breach.

4.3 Working outside the office

The corporate VPN is required on any network not owned by Northwind. Screens must not be readable by anyone outside the company, and calls covering Confidential or Restricted material are not taken in public spaces.

Devices are not left unattended in public, are locked whenever the employee steps away, and are carried as hand luggage rather than checked in.

4.4 Transfer to third parties

Confidential or Restricted information is sent outside the company only under a signed agreement covering confidentiality and, where personal data is involved, data processing. Transfer is through the approved secure transfer service; e-mail attachment is not an approved channel for these classifications.

5. Devices and Endpoints

Company work is performed on company-managed endpoints only. Managed devices carry full-disk encryption, endpoint detection, automatic patching and remote wipe, and are the only devices the company is able to protect or recover.

- Operating system and application updates are installed within seven days of release, and within twenty-four hours where the update is marked critical.
- Employees do not hold persistent local administrator rights.
- Devices lock automatically after five minutes of inactivity, and are locked manually whenever the user steps away.
- Software is installed from the approved catalogue; anything else is requested through the IT service desk.

Mobile telephones used for company e-mail or chat are enrolled in mobile device management, which applies a device passcode requirement and the ability to remove company data selectively.

6. Physical Access and Access Badges

6.1 Badges

The access badge is a personal credential and is subject to the same rules as any other credential. It is not lent, not shared, and not used to admit another person.

Badges are worn visibly on company premises. Anyone on the premises without a visible badge or visitor pass is challenged politely and directed to reception. Holding a controlled door open for someone who has not presented their own badge defeats the control entirely, however well intentioned.

6.2 Lost, stolen or damaged badges

A badge that is lost, stolen or that stops working must be reported on the same day it is discovered missing, both to Facilities Management and to Information Security. The report is made by telephone or in person; do not wait for a ticket to be picked up.

On receipt of the report the badge is deactivated immediately, so that it can no longer open any door at any site even if it is subsequently found.

A replacement badge is issued within two business days, against photo identification, carrying the same access rights as the original. A temporary pass is available from reception for the intervening period.

If a badge reported lost is later recovered, it is surrendered to Facilities Management rather than kept; a deactivated badge is not reactivated.

6.3 Visitors

Visitors are registered in advance, are issued a visitor pass against photo identification, and are

accompanied at all times by their host. A visitor is never left alone in a working area and never given a badge belonging to an employee.

7. Electronic Mail and Messaging

Phishing remains the most common route into the company. Treat as suspicious any message that creates urgency, that asks for credentials or payment details, that asks you to bypass a normal process, or that arrives unexpectedly with an attachment or a link.

Report suspected phishing using the report button in the mail client. This delivers the message to Information Security with its headers intact and removes it from the mailbox. Do not forward suspicious messages to colleagues to ask their opinion.

Requests to change bank details, whether apparently from a supplier or from a colleague, are verified by telephone on a number already held by the company, never on a number contained in the request itself.

8. Access Management

Access is granted on the principle of least privilege, for the minimum scope needed to perform the role, and is approved by the owner of the system rather than by IT.

- Access rights are reviewed quarterly by system owners; rights no longer needed are removed rather than left dormant.
- Privileged access is time-bound and requested per occasion.
- Access is revoked on the last working day as part of the leaver process, and immediately where employment ends without notice.
- A change of role triggers a full review; new access is granted and old access removed, not simply accumulated.

9. Third Parties and Software

Any external service that will process company information is assessed by Information Security before use, whatever its cost and including free tiers. The assessment covers data location, subprocessors, retention, deletion and security posture.

Open source components are consumed through the internal artifact proxy so that provenance and known vulnerabilities are tracked.

10. Training and Compliance

Security awareness training is completed on joining, before general network access is granted, and annually thereafter. Simulated phishing exercises run throughout the year; a failure results in a short additional module rather than a sanction.

Non-compliance is addressed proportionately, from correction and additional training through to disciplinary action for wilful or repeated breaches.

11. Reporting

Any suspected security incident, however small and however uncertain, is reported immediately under the incident response plan. Reporting in good faith never carries a penalty, including where the reporter caused the incident themselves. Early reporting is the single largest factor in limiting damage.

12. Related Documents

- Incident response plan
- Data retention schedule
- IT service desk handbook
- Facilities and office guide
- Code of conduct